

Documentation-Driven Threat Analysis

Base Analysis Authoring Guide

Revision 1 - Rebuild R1 - Working Foundations

Riscrittura da zero della procedura di costruzione della Base Analysis

La nuova guida non e' una revisione testuale della precedente Base Analysis Operational Guide. Viene ricostruita progressivamente a partire dalla documentazione DDTA corrente, dai problemi osservati durante l'analisi DermaTriage e dal confronto controllato con le guide e i contratti BA storici. I vecchi costrutti sono evidence da riesaminare, non contenuto ereditato automaticamente.

Stato	WORKING CANDIDATE / REWRITE FROM FIRST PRINCIPLES / NOT PROMOTED
Costrutti BA ammessi in questa revisione	Nessuno. Le famiglie, gli operatori, le signature e le cardinalita' verranno riesaminati e introdotti uno alla volta.
Caso di lavoro corrente	Ricostruzione DermaTriage, con analisi BA progressiva sul documento parallelo corrente.
Riferimenti storici	Precedente Base Analysis Operational Guide, contratti BA storici, Facial Access e precedenti analisi DermaTriage: utilizzabili per confronto, regression e recupero di concetti, non come automatica authority della nuova guida.
Guida documentale affiancata	DDTA_DOCUMENTATION_AUTHORING_GUIDE_R7_REBUILD_R8.tex - working candidate.
Data	19 settembre 2026

Boundary della revisione corrente

Questa revisione stabilisce soltanto i fondamenti necessari prima di descrivere i singoli costrutti BA. Termini come BAREferent, BAProposition, constrain, produce o altri nomi presenti nelle guide storiche e nel case study restano, per la nuova guida, **candidate vocabulary da riesaminare**. La loro presenza in un artefatto storico o di lavoro non costituisce ammissione nel nuovo metodo.

Indice

1	Scopo, lineage e regola di ricostruzione	2
2	Che cosa deve fare la Base Analysis	2
3	Authority, source-first e direzione del feedback	3
4	La struttura documentale non determina la struttura BA	3
5	Feedback strutturale BA verso la documentazione	4
5.1	Quando nasce il finding	4
5.2	Informazioni minime da registrare	5
5.3	Ritorno alla Documentation Authoring Guide	5
6	Worked pressure case: DermaTriage MR-01	5
6.1	Struttura documentale prima della review	5
6.2	Cosa ha mostrato l'analisi	6
6.3	Cosa NON conclude ancora la nuova guida BA	6
7	Protocollo per introdurre il primo costruito BA	6
8	Diagnostica durante la riscrittura	7
9	Stato corrente e prossimo passo	8

1 Scopo, lineage e regola di ricostruzione

Questa guida viene costruita con una regola diversa da una revisione incrementale tradizionale. Non si parte dalla vecchia guida chiedendo quali paragrafi modificare. Si parte invece dal problema che la Base Analysis deve risolvere e si reintroducono soltanto le distinzioni che risultano necessarie e giustificabili.

Regola di lineage

La guida BA storica e i contratti BA precedenti sono **evidence di ricerca**. Possono fornire concetti, positive control, negative control, errori già osservati e candidate solution. Nessun costrutto, operatore, ruolo o cardinalità entra nella nuova guida soltanto perché era presente nella versione precedente.

La costruzione corrente segue quindi questo ciclo:

```
documentazione DDTA bounded e sufficientemente stabile
->
lettura source-first del significato governato
->
problema analitico concreto da rappresentare
->
confronto con concetti/costrutti storici
->
prova sul caso corrente + regression su evidence precedente
->
solo se giustificato: introduzione del costrutto nella nuova guida
```

Non fare una copia selettiva della vecchia guida

Non iniziare copiando l'inventario storico dei costrutti per poi cancellare quelli che sembrano inutili. Questo renderebbe il nuovo metodo dipendente dalla vecchia decomposizione. La riscrittura procede nella direzione opposta: esigenza semantica concreta prima, costrutto dopo.

2 Che cosa deve fare la Base Analysis

La *Base Analysis* è uno strato analitico condiviso tra documentazione governata e consumer downstream. Deve rendere il significato necessario sufficientemente esplicito, stabile e riusabile per analisi successive senza trasformarsi in una seconda documentazione di progetto e senza completare ciò che il progetto non ha deciso.

Project truth rimane nella documentazione

La documentazione governata è la sorgente del significato del progetto. La BA può normalizzare, rendere esplicite relazioni analitiche, conservare provenance e rendere il significato consumabile; non può introdurre silenziosamente un commitment di progetto mancante.

La domanda centrale della nuova guida è:

Domanda centrale

Dato un insieme bounded di documentazione DDTA, qual e' il minimo significato analitico che deve essere reso esplicito per poterlo riusare, verificare, confrontare e consumare downstream senza rileggere la prosa e senza inventare project truth?

Il termine *minimo* non significa "piu' corto possibile". Significa: nessuna distinzione necessaria viene persa e nessuna distinzione non giustificata viene introdotta.

3 Authority, source-first e direzione del feedback

La direzione dell'autorita' e' un vincolo del metodo:

```
project sources / governed decisions
    ->
DDTA documentation
    ->
Base Analysis
    ->
projection / threat analysis / test / other consumers
```

Il feedback puo' invece viaggiare verso monte senza invertire l'autorita':

```
downstream finding
    -> BA review
    -> documentation review trigger
    -> governed documentation change, if justified
    -> BA revalidation / rebuild
```

No authority inversion

Un finding BA puo' dimostrare che la documentazione e' ambigua, ridondante, insufficiente o strutturalmente difficile da usare. Non puo' correggere da solo la project truth. La correzione avviene nel layer documentale competente; solo dopo la BA viene riallineata.

Durante la riscrittura source-first si preservano esplicitamente almeno questi stati:

- significato supportato dalla documentazione;
- significato contraddetto dalla documentazione;
- significato non stabilito / NOT SPECIFIED;
- conflitto tra fonti o tra commitment governati;
- necessita' analitica non ancora rappresentabile con il vocabolario BA ammesso fino a quel momento.

4 La struttura documentale non determina la struttura BA

Prima di introdurre qualsiasi costrutto BA serve fissare una regola di cardinalita'.

Indipendenza strutturale

Gli elementi documentali sono sorgenti di significato governato, non un template da riprodurre uno-a-uno nella Base Analysis.

In particolare:

```
numero di MacroRequirement / Decision / FunctionalRequirement
    !=
numero di future identita' analitiche
    !=
numero di future asserzioni analitiche
```

Quindi non e' ammesso assumere regole del tipo:

```
one Decision -> one BA element
one FunctionalRequirement -> one BA proposition
one documentation branch -> one analytical branch
```

Due elementi documentali possono contribuire allo stesso significato analitico. Un singolo elemento documentale puo' invece governare piu' significati analiticamente distinguibili. La corretta cardinalita' emerge dall'analisi del significato, non dalla forma dell'albero documentale.

Traduzione meccanica

La BA non e' una serializzazione dell'albero DDTA. Se la struttura documentale viene copiata meccanicamente, la successiva analisi non distingue piu' quali identita' e quali relazioni servano davvero e quali esistano soltanto per ragioni di authoring.

5 Feedback strutturale BA verso la documentazione

Questa sezione viene intenzionalmente prima dei singoli costrutti. Stabilisce cosa fare quando l'analisi rende visibile un problema nella decomposizione documentale.

5.1 Quando nasce il finding

Durante la normalizzazione puo' accadere che due branch documentali distinti non producano due conseguenze analitiche autonomamente utili. Un branch puo' contenere un significato reale e source-supported, ma quel significato puo' essere necessario soltanto all'interno del contratto operativo governato da un altro branch.

In questo caso la BA non deve forzare artificialmente due strutture analitiche per rispettare la cardinalita' documentale.

Diagnostic corrente

Registrare il finding POSSIBLE_UPSTREAM_STRUCTURAL_REDUNDANCY quando una separazione documentale appare priva di utilita' analitica autonoma e il significato del branch puo' essere preservato nel branch che possiede i comportamenti correlati.

Il finding non significa automaticamente che la documentazione sia errata. Significa soltanto che deve essere riaperta la review della struttura.

5.2 Informazioni minime da registrare

Il finding deve indicare almeno:

1. quali branch o elementi documentali sono coinvolti;
2. quale significato governato appartiene a ciascuno;
3. quale significato resta analiticamente distinguibile;
4. quali conseguenze downstream autonome sono state cercate;
5. perché la separazione appare utile oppure superflua;
6. quale review documentale deve essere riaperta.

Non deve invece contenere una modifica documentale applicata direttamente dalla BA.

5.3 Ritorno alla Documentation Authoring Guide

La decisione strutturale appartiene alla guida di documentazione. Il finding BA attiva il test documentale:

Downstream Utility Test - eseguito nel layer documentale

Se elimino questo branch come ramo autonomo e trasferisco il suo significato nella Decision che possiede i relativi comportamenti, perdo una distinzione necessaria per implementazione, verifica, modifica indipendente o analisi?

- **SI**: il branch possiede una conseguenza downstream distinguibile e la separazione può essere giustificata;
- **NO**: la documentazione riesamina il branch per MERGE o REWORK, preservando il significato utile senza mantenere struttura puramente sintattica.

La BA si riallinea soltanto dopo l'eventuale modifica governata della documentazione.

6 Worked pressure case: DermaTriage MR-01

Il caso DermaTriage ha esposto il problema prima che la nuova guida BA avesse ammesso un proprio inventario di costrutti. Per questo viene usato qui come **pressure case sul processo**, non come definizione di operatori BA.

6.1 Struttura documentale prima della review

Il significato rilevante era separato in due branch:

```
DEC-MR01-02
  scelta del dominio della prioritá operativa P1-P4
  |
  +-- FR-MR01-02-01
      la prioritá deve appartenere a {P1,P2,P3,P4}

DEC-MR01-04
  separazione tra urgenza analitica e prioritá operativa
  + derivazione successiva
```

```

|
+-- FR-MR01-04-01
    HIGH + confidence > 0.85 -> P1
    HIGH                                -> P2
    MEDIUM                            -> P3
    LOW                               -> P4

```

La scelta P1-P4 era semanticamente reale. Il problema non era quindi “DEC-MR01-02 e’ falsa”.

6.2 Cosa ha mostrato l’analisi

L’analisi ha mostrato due fatti contemporaneamente:

1. il dominio della priorita’ e la regola di mapping sono significati distinguibili;
2. la scelta del dominio, come branch documentale autonomo, non produceva un proprio percorso operativo indipendente: il suo uso concreto avveniva nel branch che governa la derivazione della priorita’.

Questa combinazione e’ importante: **distinzione semantica non equivale automaticamente a branch documentale autonomo**.

Esito della review documentale

Il significato “la priorita’ operativa usa il dominio P1-P4” viene preservato dentro il contratto di DEC-MR01-04. FR-MR01-04-01 continua a governare il mapping concreto. Il branch DEC-MR01-02 / FR-MR01-02-01 viene quindi consolidato senza perdere il significato P1-P4.

6.3 Cosa NON conclude ancora la nuova guida BA

Il case study contiene nomi e forme provenienti dalla precedente fase di BA, ad esempio candidate representation come constrain o decisionRule. In questa nuova guida tali nomi restano soltanto evidence da riesaminare.

Construct admission ancora aperta

Non e’ ancora stato deciso con quale costrutto BA rappresentare il dominio P1-P4, il mapping urgenza/confidence, la relazione tra i due significati o la loro eventuale identita’ analitica ri-usabile. Questa decisione verra’ presa quando l’analisi riprendera’ dal branch DEC-MR01-04 / FR-MR01-04-01 applicando il protocollo della sezione successiva.

7 Protocollo per introdurre il primo costrutto BA

La nuova guida non contiene ancora un catalogo di elementi. Ogni costrutto viene ammesso soltanto attraverso un caso concreto.

Construct admission rule

Prima si identifica una distinzione analitica necessaria e source-supported. Solo dopo si valuta se serve un costrutto dedicato e come deve essere definito. Il nome storico del costrutto e’ una candidate solution, non il punto di partenza.

Per ogni possibile costrutto applicare questa sequenza:

1. **Evidence need:** indicare il significato documentale che deve essere preservato e la domanda downstream che lo rende necessario.
2. **Minimal semantic unit:** descrivere la distinzione senza usare ancora il nome dell'operatore o della famiglia storica.
3. **Historical comparison:** verificare come la vecchia guida rappresentava quel significato e quali problemi aveva già incontrato.
4. **Alternative representations:** verificare se il significato può essere rappresentato senza introdurre una nuova primitiva o senza mantenere una primitiva storica non necessaria.
5. **Positive control:** almeno un caso source-grounded in cui il costrutto preserva una distinzione necessaria.
6. **Negative control:** almeno un caso vicino in cui usare il costrutto produrrebbe un'inferenza falsa o una distinzione artificiale.
7. **Contract:** solo a questo punto definire semantica, eventuali ruoli, cardinalità, invarianti e boundary.
8. **Regression:** riesaminare il caso corrente e l'evidence storica pertinente per verificare che la definizione non perda significato o introduca project truth.
9. **Admission:** aggiungere il costrutto alla guida come working construct, ancora falsificabile dai casi successivi.

Forbidden shortcut

“La vecchia guida aveva X, quindi usiamo X” non è una giustificazione. La domanda corretta è: “quale distinzione deve essere preservata, e X è ancora la rappresentazione minima e corretta dopo il nuovo test?”

8 Diagnostica durante la riscrittura

Quando l'analisi non procede, il problema va localizzato prima di cambiare il metodo. Le classi di lavoro correnti sono:

Classe	Domanda
Source / documentation gap	Il significato necessario manca o resta ambiguo nella documentazione?
Documentation-authoring problem	Il significato esiste nelle fonti ma la struttura DDTA corrente lo rende ambiguo, duplicato o non operativo?
BA representation problem	Il significato è sufficientemente governato ma la nuova BA non ha ancora un modo fedele di rappresentarlo?
BA construct pressure	Serve introdurre o cambiare un costrutto per un counterexample concreto?
Downstream-only issue	La difficoltà appartiene al consumer e non richiede nuovo significato condiviso nella BA?
No gap	La differenza è soltanto di presentazione o naming e non richiede modifica metodologica.

Minimum owning layer

Ogni modifica deve essere applicata al minimo layer che possiede realmente il problema. Un problema documentale non si risolve inventando semantica BA; un problema BA non si scarica sulla documentazione; una necessita' specifica di un threat method non diventa automaticamente semantica condivisa.

9 Stato corrente e prossimo passo

Alla chiusura di questa revisione i fondamenti precedenti sono disponibili per guidare l'analisi, ma **nessun singolo costrutto BA e' ancora ammesso nella nuova guida.**

Il prossimo bounded step e' deliberatamente piccolo:

DermaTriage MR-01

DEC-MR01-04

dominio P1-P4 + separazione urgenza/priorita'

FR-MR01-04-01

mapping urgency/confidence -> P1-P4

1. descrivere i semantic atom necessari senza usare operatori storici;
2. verificare identita', relazione e comportamento realmente richiesti;
3. confrontare le candidate solution della vecchia guida;
4. riesaminare uno solo dei costrutti storici alla volta;
5. introdurre nella nuova guida soltanto cio' che supera il test.

Stop condition della R1 Rebuild R1

Non aggiungere una sezione "BAReferent", "BAProposition" o un inventario di operatori finche' il primo costrutto non e' stato riesaminato attraverso evidence corrente, confronto storico, positive control, negative control e regression.